

Sohken: real-world problems and prioritized backlog

Research date: 16 September 2026 • Scope: production RAG and tool-using agents • Delivery assumption: solo builder, lowest-cost deployment

Main finding

The strongest first product is a controlled execution and evidence layer for a bounded engineering-support workflow. It should prove that a requested action was permitted, actually executed, and achieved its intended state. A general agent dashboard or injection detector alone has substantial overlap with existing tools. This product choice is a hypothesis to validate with users, not an established market gap.

The supplied PDF is a useful concept specification. It is not implementation evidence. Its nine broad failure classes are expanded below into 32 concrete, testable problems. No Sohken software or customer results currently exist in this workspace.

What the evidence actually says

1. **A real product vulnerability:** Microsoft acknowledges the now-fixed EchoLeak flaw, where crafted email could cause limited internal-data disclosure in certain conditions. This establishes a production-product failure mode; it does not establish current vulnerability or observed customer exploitation. [S01](#)
2. **A practical attack demonstration:** Invariant showed a public GitHub issue redirecting an agent to read private repositories and publish information in a public pull request. The demonstration depended on the configured access and approval behavior. [S02](#)
3. **A tool supply-chain demonstration:** Malicious tool descriptions can influence an agent before the particular malicious tool is executed. Trusting the tool name or its signature does not establish benign semantics. [S03](#)
4. **A reliability measurement:** The original 2024 tau-bench found under 50% success for tested agents and retail pass⁸ under 25%. Those historical results justify repeated, state-based evaluation; they are not estimates for today's models. [S05](#)
5. **An evaluation gap:** AgentDojo and newer automated-attack research demonstrate why benign utility and adversarial behavior must be measured separately, with held-out attacks and model-specific results. [S04](#), [S06](#)

Corrections and missing boundaries in the PDF

PDF assumption	Research assessment	Required change
NVIDIA guardrails do not cover tool misuse/output paths	Too broad as a current claim. Current tool rails check calls and result structure; they have explicit limitations.	Differentiate on enforced execution, contextual authorization, approval integrity, and verified outcomes. S08
An OpenAI-compatible proxy connects the control plane	Useful for model traffic; insufficient to stop direct tool execution.	Gateway must control tool credentials and the execution path. Unmanaged external tools remain outside the guarantee.
Rollback is a general incident control	Many effects cannot be undone: delivered mail, leaked data, external notifications.	Label reversible operations, define compensation, and forbid unsupported rollback claims.
Replaying a trace reproduces a run	Live providers, indexes, and external state change.	Separate recorded playback, sandbox re-execution, and live reruns.
95% citation coverage means grounding quality	A citation can be irrelevant or contradictory.	Measure claim support and appropriate abstention separately.
Security can wait until deployment packaging	Retrofitting identity into tools, approvals, and traces is expensive.	Start with authenticated scope, least privilege, and environment isolation.
A small company can build the entire platform as an MVP	Too broad for one builder.	One tenant per deployment, one workflow, fixed tools, local first; defer shared SaaS and arbitrary code.
Trace viewer is a product distinction	Langfuse and LangSmith already document rich evaluation/observability capabilities.	Reuse/export telemetry; validate whether action-control gaps justify a new product. S15 , S16

Priority and evidence rules

P0 blocks the first connected private pilot. **P1** is necessary for a credible pilot/release, but parts can follow the initial safe local slice. **P2** is deferred until demand or scale justifies it. Priority reflects potential harm, exposure in the chosen workflow, and dependency order; it is not a measured occurrence rate. All entries are open. The solo builder is the proposed implementation owner; a pilot operator must own actual service changes.

Evidence labels: V = confirmed product vulnerability; D = demonstration; B = benchmark; G = guidance/documentation; H = proposed failure scenario or commercial hypothesis. The source supports the mechanism; each Sohken test and mitigation below is a design proposal. S00 pN refers to the supplied PDF. Full source details: [research sources](#).

Security and authority

P01 — Retrieved content redirects the agent

- **Priority / evidence:** P0 • V/D/B: S01, S02, S04 • PDF p1, p2
- **Scenario / impact:** An incident ticket or log contains instructions to disclose credentials or change another service; the agent treats evidence as authority.
- **Build response:** Preserve source identity, keep task authorization external to prompts, restrict tools and destinations, and treat detection as an additional signal.
- **Acceptance test:** Put malicious instructions into each supported input surface. Forbidden actions must remain blocked even when the model follows the injected request; report benign-task losses separately.

P02 — Tool metadata is poisoned or changes after approval

- **Priority / evidence:** P0 • D: S03 • PDF p1
- **Scenario / impact:** A registered tool's description or endpoint changes and requests unrelated private information.
- **Build response:** Pin schema, description, endpoint and executable/image digest; require owner review for changes. A signature establishes origin, not safety.
- **Acceptance test:** Alter one registered field after approval. Execution must reject the new version until it is explicitly re-registered and approved.

P03 — The agent bypasses the model proxy

- **Priority / evidence:** P0 • H, informed by G: S11 • PDF p2
- **Scenario / impact:** An SDK logs safe model calls while the agent directly invokes an API using inherited credentials.
- **Build response:** Keep downstream credentials in the tool runner only; restrict agent network access and deny unmanaged tool paths.
- **Acceptance test:** Attempt direct calls from the agent process to the mock protected service. They must fail independently of prompts and model decisions.

P04 — User authority becomes excessive agent authority

- **Priority / evidence:** P0 • G/D: S09, S02 • PDF p1
- **Scenario / impact:** A user's broad token lets a support agent read unrelated repositories or impersonate another project.
- **Build response:** Intersect user permissions, workflow scope, resource scope, environment, and tool capability; validate token audience. Use separate downstream credentials.
- **Acceptance test:** Substitute user, tenant, environment, resource, and token audience one at a time. Deny every unauthorized combination.

P05 — Data crosses a forbidden destination boundary

- **Priority / evidence:** P0 • V/D: S01, S02 • PDF p1
- **Scenario / impact:** Private diagnostic data is placed in a public ticket, URL, telemetry export, or unapproved model request.
- **Build response:** Restrict model providers and tool destinations; propagate data sensitivity conservatively and block forbidden source-to-destination flows.
- **Acceptance test:** Seed fake secrets and confidential markers; inspect model requests, tool bodies, URLs and telemetry. Zero prohibited egress in the defined suite; redaction alone is insufficient.

P06 — An approval is reused or applies to different arguments

- **Priority / evidence:** P0 • H; authority context from S09 • PDF p2
- **Scenario / impact:** The user approves one service change, but a queued call executes against another resource or after a policy change.
- **Build response:** Bind approval to immutable argument hash, tool version, resource revision, actor, run, scope, policy version, expiry and a single-use nonce.
- **Acceptance test:** Replay, mutate, expire, revoke and concurrently consume approvals. Only one matching execution may be admitted.

P07 — Human approval becomes a misleading ritual

- **Priority / evidence:** P1 • G/H: S12 • PDF p3
- **Scenario / impact:** A plausible model summary conceals a broad action; repetitive prompts train the operator to approve without reading.
- **Build response:** Show exact destination, affected resource, structured diff, expected outcome, expiry and reversibility; derive these from the execution envelope.
- **Acceptance test:** In usability sessions, operators correctly identify a dangerous destination and reject stale approvals. Measure review time and mistaken approval, without claiming statistical certainty from a tiny sample.

P08 — Tenant or environment isolation leaks

- **Priority / evidence:** P0 • G/H: S19 • PDF p1, p2
- **Scenario / impact:** A query, embedding search, cache, export or trace lookup returns another customer's data or production data in a test run.
- **Build response:** First deploy one tenant per instance; separate dev/pilot credentials and data. For future shared hosting, enforce database and object-store scope everywhere.
- **Acceptance test:** Cross-scope ID substitution across retrieval, approvals, runs and exports yields no data. Test database roles that cannot bypass isolation.

P09 — Tool execution escapes its intended boundary

- **Priority / evidence:** P0 • G: S18 • PDF p2
- **Scenario / impact:** Path traversal, unsafe shell arguments, network access or a privileged container exposes the host.
- **Build response:** Fixed typed adapters, no general shell, read-only mounts, non-root runner, resource caps, no Docker socket, and restricted egress.
- **Acceptance test:** Probe traversal, symlinks, redirects, metadata endpoints, forbidden mounts and oversized inputs in an isolated fixture environment.

P10 — Policy failure silently permits execution

- **Priority / evidence:** P0 • G/H: S17 • PDF p2
- **Scenario / impact:** A policy loader accepts an invalid rule or the decision service times out; application code defaults to allow.
- **Build response:** Reject unknown decisions and invalid policy versions. Fail closed for protected actions; explicitly define any permitted cached read policy.
- **Acceptance test:** Corrupt policy configuration, stop the engine and expire cached policy. No write may execute without a valid current decision.

P11 — Memory keeps a poisoned instruction alive

- **Priority / evidence:** P2 • G: S12 • PDF gap
- **Scenario / impact:** A malicious instruction saved as a helpful note affects later users or sessions.
- **Build response:** Disable persistent agent memory initially. If added, use scoped records, provenance, expiry, separate write approval and quarantine.
- **Acceptance test:** Poison one session and start another. No unapproved memory crosses sessions or scope boundaries.

Reliability and verified outcomes

P12 — Retries duplicate external side effects

- **Priority / evidence:** P0 • G: S10 • PDF p1
- **Scenario / impact:** A ticket is created but the response times out; a retry creates a second ticket.
- **Build response:** Stable logical-action IDs, provider idempotency keys where supported, durable action ledger, and reconciliation after ambiguous outcomes.
- **Acceptance test:** Drop the response after commit and redeliver the job. One remote effect for supported adapters; otherwise stop in UNKNOWN and reconcile rather than retry blindly.

P13 — The agent reports success after partial failure

- **Priority / evidence:** P0 • B/H: S05 • PDF p1
- **Scenario / impact:** An API returns HTTP success with an application error, or only part of the intended update occurs.
- **Build response:** Normalize transport and application errors; verify postconditions through an independent read; distinguish success, partial, failed and unknown.
- **Acceptance test:** Inject malformed responses, application errors and partial writes. Final status must match the authoritative fixture state.

P14 — Authorization goes stale while work waits

- **Priority / evidence:** P0 • H • PDF gap
- **Scenario / impact:** A user or tool is revoked after a job is queued; the worker executes old permissions.
- **Build response:** Revalidate current scope and revocation at dispatch; use a short-lived execution capability and resource precondition checks.
- **Acceptance test:** Revoke between queueing, approval and dispatch. Undispatched actions stop; already committed external effects are reported honestly.

P15 — A workflow cannot recover after a crash

- **Priority / evidence:** P1 • G/H: S10 • PDF p1
- **Scenario / impact:** A process dies after reserving budget or starting a tool call, leaving orphaned approvals and uncertain actions.
- **Build response:** Durable state transitions, leased jobs, transactional outbox and recovery reconciliation; do not use an in-memory queue as truth.
- **Acceptance test:** Kill the worker at each transition. Restart preserves decisions, releases safe reservations and flags uncertain actions without duplicate writes.

P16 — Provider outages trigger retry storms or unsafe fallback

- **Priority / evidence:** P1 • H; distributed-systems context S10 • PDF p1
- **Scenario / impact:** Rate limits create cascading retries; fallback sends private prompts to an unapproved provider or weaker model.
- **Build response:** Deadlines, capped jittered retries, concurrency limits and an explicit provider/data-policy matrix. Re-evaluate quality before promoting fallback.
- **Acceptance test:** Inject timeouts and rate limits. Queue growth and spend remain bounded; disallowed provider fallback never occurs.

P17 — Concurrent agents exceed the run budget

- **Priority / evidence:** P0 • H • PDF p1, p3
- **Scenario / impact:** Several calls each see enough remaining balance and jointly overspend; recursion continues indefinitely.
- **Build response:** Atomic reservations before calls, maximum output sizes, step/depth/deadline caps, and conservative pricing estimates.
- **Acceptance test:** Concurrently request the final budget balance. Admitted reservations remain within the cap; track delayed billing separately from enforcement.

P18 — Rollback or replay creates further harm

- **Priority / evidence:** P0 • H • PDF p2, p3
- **Scenario / impact:** Replaying an incident sends another message, or a rollback overwrites a newer human change.
- **Build response:** Playback uses recorded results; re-execution uses isolated fixtures. Compensation is an explicit action with fresh approval and state preconditions.
- **Acceptance test:** Replay performs zero external writes; compensation against a changed revision refuses and escalates.

Retrieval and evaluation

P19 — Retrieval returns stale or unauthorized evidence

- **Priority / evidence:** P0 • G/H: S19 • PDF p1, p2
- **Scenario / impact:** A revoked document remains in the index; an old runbook recommends a now-dangerous action.
- **Build response:** Check scope at retrieval time, retain document/chunk versions and freshness, and invalidate deleted/revoked material and caches.
- **Acceptance test:** Revoke a document after indexing and replace a runbook. Search, cache, evidence export and citations must respect the new access state.

P20 — Citations exist but do not support claims

- **Priority / evidence:** P1 • H • PDF p3
- **Scenario / impact:** A confident incident diagnosis links to a real but irrelevant runbook.
- **Build response:** Use claim-to-source-span mapping, support judgments, contradictory-source handling and abstention for missing evidence.
- **Acceptance test:** Include plausible irrelevant and contradictory citations; score coverage and actual support separately with human-audited labels.

P21 — Similar requests produce inconsistent outcomes

- **Priority / evidence:** P1 • B: S05 • PDF p1
- **Scenario / impact:** The same incident receives a correct diagnosis once and an unsupported change recommendation later.
- **Build response:** Version all dependencies, repeat each task, and test final state and policy compliance across runs.
- **Acceptance test:** Run each held-out scenario five times per selected configuration; report mean success and fraction of tasks succeeding on all five attempts.

P22 — A detector blocks legitimate work

- **Priority / evidence:** P1 • B/G: S04, S07 • PDF p3
- **Scenario / impact:** Log lines discussing attacks are treated as attacks; security improves only because the agent refuses everything.
- **Build response:** Separate hard authorization from probabilistic detection; calibrate with matched benign and adversarial cases.
- **Acceptance test:** Publish attack success, benign false-block rate and useful task completion together. An all-deny configuration is a failed product baseline.

P23 — Benchmarks overstate security

- **Priority / evidence:** P1 • B: S04, S06 • PDF p3
- **Scenario / impact:** Developers tune against known strings, while unseen multi-step attacks succeed.
- **Build response:** Freeze a held-out suite split by scenario/source, include adaptive paraphrases and retain failures; keep attack tuning away from release labels.
- **Acceptance test:** Evaluate held-out attacks at fixed budget and report confidence intervals by family. Do not count repeated variants as independent proof of safety.

P24 — The grader trusts the agent's story

- **Priority / evidence:** P1 • B/H: S05 • PDF p1, p3
- **Scenario / impact:** An LLM judge marks success because the answer says the operation completed, even though the database disagrees.
- **Build response:** State assertions first; structured output checks second; human-calibrated language judges only for semantic criteria.
- **Acceptance test:** Supply persuasive false success messages and judge-targeting text. Final-state assertions must fail them regardless of narrative quality.

Operations, economics and adoption

P25 — Observability becomes a secret store

- **Priority / evidence:** P0 • G/H: S14 • PDF p1, p2
- **Scenario / impact:** Full prompts, tool arguments and retrieved text appear in logs accessible to more people than the source data.
- **Build response:** Metadata-only telemetry by default; sanitized payload references, restricted encrypted debug capture, retention and deletion rules.
- **Acceptance test:** Seed fake credentials in every stage. Ordinary traces, errors, backups and exports must not contain them; privileged captures have explicit access controls.

P26 — Audit evidence is missing or editable

- **Priority / evidence:** P1 • G/H: S13 • PDF p1
- **Scenario / impact:** An operator cannot tie a write to an approval, or the same administrator can rewrite its entire evidence history.
- **Build response:** Durable pre-action records, append-only application permissions, hash-linked entries and periodic off-host signed checkpoints.
- **Acceptance test:** Delete/reorder/modify an event and validate against a retained independent checkpoint. Report that a compromised host/key can still undermine evidence.

P27 — SDK, model or telemetry changes break enforcement

- **Priority / evidence:** P1 • G: S08, S14 • PDF p1
- **Scenario / impact:** Streaming arguments execute before validation, an adapter drops scope, or an exporter changes attribute meaning.
- **Build response:** Pin tested versions, normalize complete requests, reject unknown capabilities and run contract tests for every upgrade.
- **Acceptance test:** Fragment tool calls across stream chunks and change tool schemas. No execution before complete validation; exporter migrations preserve required fields.

P28 — The control plane becomes an availability bottleneck

- **Priority / evidence:** P1 • H • PDF p1, p2
- **Scenario / impact:** Slow evaluation, a full disk or an unavailable database prevents incident support when it is needed most.
- **Build response:** Keep grading asynchronous; bound queues and payloads; reserve disk; expose readiness and explicit degraded states. Retain a human manual workflow.
- **Acceptance test:** Fill storage, slow dependencies and overload the queue in staging. Deny unrecordable writes, preserve committed evidence, and show an actionable error.

P29 — Backups exist but cannot restore service

- **Priority / evidence:** P1 • H • PDF p1, p3
- **Scenario / impact:** A single low-cost host fails and backups lack encryption keys, policy versions or a consistent ledger.
- **Build response:** Encrypted off-host backups, documented key custody and restore drills; reconcile external actions after restoring an older ledger.
- **Acceptance test:** Restore to a clean instance and replay fixtures. Verify evidence integrity and ensure restored pending jobs cannot recreate external effects.

P30 — Compliance and procurement exceed the product's claims

- **Priority / evidence:** P1 • G/H: S13 • PDF p3
- **Scenario / impact:** A pilot requires data residency, retention, subprocessor disclosure or access controls that the builder cannot demonstrate.
- **Build response:** Document data inventory, destinations, retention, access and deletion; agree pilot restrictions. Obtain jurisdiction-specific review only when needed.
- **Acceptance test:** Produce a data-flow inventory and a deletion/export demonstration. Do not label the product certified or compliant from a framework mapping alone.

P31 — Integration costs exceed customer value

- **Priority / evidence:** P1 • H; overlap documented in S15, S16 • PDF p3
- **Scenario / impact:** Each customer requires custom adapters and already has a dashboard; no one pays for the additional control layer.
- **Build response:** Interview operators, integrate one fixed workflow, compare against their current process and track setup/maintenance time.
- **Acceptance test:** Proposed discovery gate: five interviews, two concrete workflow commitments, one deployer other than the builder. These are decision rules, not measured demand.

P32 — The solo builder cannot operate the proposed stack

- **Priority / evidence:** P0 • H • PDF p2, p3
- **Scenario / impact:** Kubernetes, multiple data stores, GPU inference and many adapters consume the schedule before the first user succeeds.
- **Build response:** One modular service, one worker, PostgreSQL, fixed tools and minimal UI; local-first, no GPU requirement, one tenant per pilot instance.
- **Acceptance test:** A fresh user follows the documented local setup and runs the fixture demo without external paid credentials. Measure setup time; reduce scope when it exceeds the proposed 30-minute target.

Implementation order

1. **Authority foundation:** P03, P04, P08, P09, P10, P32.
2. **Safe action transaction:** P06, P12, P13, P14, P17, P18, P25.
3. **Evidence and adversarial cases:** P01, P02, P05, P19–P24.
4. **Pilot readiness:** P07, P15, P16, P26–P31.
5. **Only after demand:** P11 and stronger shared-host/multi-agent capabilities.

P0 does not mean every countermeasure needs a separate subsystem. For example, disabling arbitrary code and persistent memory removes entire exposure paths from the first release. Any deferred P0 mechanism requires an explicit scope restriction that removes its exposure.

Questions the pilot must answer

- Is unauthorized action prevention a problem customers will pay to solve, beyond their existing observability stack?
- Can a third party route all protected tools through Sohken without bypass credentials?
- Can operators understand approvals without materially slowing their work?
- Does the workflow save time while maintaining supported answers and correct final state?
- What failures appear only in real, messy logs and runbooks?

These require user evidence. Public research cannot establish Sohken's product-market fit.

Linked references

S01 Microsoft EchoLeak discussion; S02 GitHub MCP demonstration; S03 Tool poisoning; S04 AgentDojo; S05 tau-bench; S06 Automated attacks; S07 Anthropic defenses; S08 NVIDIA tool rails; S09 MCP security; S10 Safe retries; S11 Excessive agency; S12 OWASP Agentic 2026; S13 NIST GenAI profile; S14 OTel conventions; S15 Langfuse; S16 LangSmith evaluation; S17 OPA bundles; S18 gVisor security; S19 PostgreSQL row security.